

TRACELENS AI

Panduan Lengkap Penjelasan Sistem
dan Hasil Review Teknis

EVIDENCE-GROUNDED LOG INVESTIGATION

Dokumen audiensi dan speaker guide

Status review: Strong MVP - belum production-ready

28 Juli 2026

Dokumen ini menjelaskan visi, arsitektur, alur investigasi, kontrol keamanan, hasil validasi, temuan teknis, roadmap, skenario demo, dan FAQ TraceLens AI.

Daftar Isi

1. Ringkasan Eksekutif	5
2. Cara Menjelaskan Produk dalam 60 Detik	5
3. Masalah yang Diselesaikan	6
3.1 Fragmentasi log	6
3.2 Timeline manual	6
3.3 Korelasi entitas	6
3.4 Risiko halusinasi AI	6
4. Prinsip Arsitektur	6
5. Gambaran Arsitektur Sistem	7
4.1 Konfigurasi AI yang sedang digunakan	7
5.1 Trust boundary	7
6. Alur End-to-End	8
6.1 Membuat case	8
6.2 Upload evidence	8
6.3 Parsing	8
6.4 Timeline dan correlation	8
6.5 Detection dan risk scoring	8
6.6 AI investigation	9
6.7 Claim verification gate	9
7. Fitur yang Dilihat Audiensi	10
7.1 Case Dashboard	10
7.2 Log Upload	10
7.3 Timeline	10
7.4 Event Explorer	10
7.5 AI Investigator Chat	10
7.6 Findings and Report	10
8. Model Data Inti	10
9. Kontrol Keamanan yang Sudah Ada	10
9.1 Authentication dan session	10
9.2 Authorization dan case isolation	11
9.3 Upload security	11
9.4 Prompt injection defense	11
9.5 Container hardening	11

10. Hasil Validasi Aktual	11
11. Scorecard Review	12
12. Temuan Prioritas Tinggi	13
12.1 Fresh database migration berpotensi gagal	13
12.2 Race condition rebuild analysis	13
12.3 Frontend production dependencies rentan	13
12.4 Secret pernah masuk Git history	14
12.5 Login belum di-rate-limit	14
12.6 Unknown input diterima sebagai generic text	14
13. Temuan Prioritas Menengah	14
13.1 Agent run gagal dapat tetap berstatus running	14
13.2 Test suite masih unit-heavy	14
13.3 Readiness hanya memeriksa database	15
13.4 Backup belum mencakup evidence	15
13.5 Worker membaca seluruh file ke memori	15
14. Threat Model Ringkas	15
15. Roadmap Perbaikan	15
P0 - Sebelum deployment publik	15
P1 - Production candidate	16
P2 - Forensic assurance	16
16. Skenario Demo yang Direkomendasikan	16
Langkah demo	16
Hal yang jangan diklaim saat demo	16
17. FAQ Audiensi	17
Mengapa tidak menyerahkan semua log langsung kepada AI?	17
Apakah evidence ID menghilangkan halusinasi sepenuhnya?	17
Mengapa raw log harus disimpan?	17
Apakah risk score adalah machine learning?	17
Apakah sistem menggantikan SOC analyst?	17
Apakah Windows EVTX didukung?	17
Apa yang terjadi jika GitHub Models gagal?	17
Apa pembeda utama TraceLens?	17
18. Panduan Presentasi 12 Menit	18
19. Penutup	18
Lampiran A - Checklist sebelum presentasi	18

TraceLens AI adalah asisten investigasi log keamanan siber yang mengubah log mentah menjadi event terstruktur, timeline insiden, correlation, finding, dan jawaban AI yang dapat ditelusuri kembali ke bukti asli.

Pesan utama: AI membantu investigator memahami bukti, tetapi tidak menggantikan bukti. Setiap klaim yang ditampilkan harus memiliki evidence ID valid dan tetap dapat diperiksa pada baris log asli.

1. Ringkasan Eksekutif

TraceLens AI dibangun untuk mengatasi tiga masalah investigasi log:

- log berasal dari format berbeda dan sulit dibandingkan;
- investigator harus menyusun urutan kejadian secara manual;
- jawaban AI generatif berisiko terdengar meyakinkan walaupun tidak didukung bukti.

Sistem memisahkan pekerjaan deterministik dan generatif. Parsing, normalisasi timestamp, sorting, correlation, detection rule, dan risk scoring dilakukan oleh kode biasa. Model bahasa hanya boleh merencanakan investigasi, memilih tool database, menyusun interpretasi, dan membuat laporan.

Hasil review menunjukkan fondasi arsitektur dan evidence grounding sudah kuat untuk MVP, demo, penelitian, dan staging terkontrol. Sistem belum layak disebut production-ready atau forensic-grade sebelum menyelesaikan masalah migration database, concurrency analysis, dependency vulnerability, riwayat secret, dan pengujian integrasi.

Keputusan penggunaan	Status	Penjelasan
Demo lokal dan presentasi	Layak	Seluruh layanan utama berjalan dan alur inti tersedia
Penelitian dan portfolio	Layak	Arsitektur dan batas AI terdokumentasi dengan baik
Staging terkontrol	Layak bersyarat	Gunakan data non-sensitif dan akses terbatas
Internet publik	Belum layak	Masih ada security dan reliability blocker
Bukti forensik formal	Belum layak	Belum ada WORM, signed audit trail, dan validasi operasional formal

2. Cara Menjelaskan Produk dalam 60 Detik

Gunakan narasi berikut:

TraceLens AI adalah platform investigasi log berbasis bukti. Investigator membuat case dan mengunggah log. Sistem menghitung SHA-256, mendeteksi format berdasarkan isi, lalu mem-parsing setiap baris secara deterministik. Semua event disatukan menjadi timeline dan dikorelasikan berdasarkan IP, username, atau session. Rule engine mencari pola seperti brute force dan login berhasil setelah kegagalan berulang. AI kemudian memakai tool read-only untuk menanyakan data yang sudah diproses. Sebelum jawaban ditampilkan, claim verification gate memastikan setiap klaim mempunyai evidence ID valid dari case aktif. Investigator dapat membuka citation dan melihat raw log serta nomor baris aslinya.

Tiga kalimat yang perlu ditekankan:

1. LLM tidak melakukan parsing dan tidak menentukan urutan timeline.
2. Setiap klaim AI harus memiliki bukti yang bisa dibuka.

3. Jika bukti tidak cukup, sistem harus menyatakannya secara jujur.

3. Masalah yang Diselesaikan

3.1 Fragmentasi log

Satu insiden dapat meninggalkan jejak pada Linux authentication log, web access log, dan log aplikasi. Format timestamp, nama field, serta tingkat severity dapat berbeda. TraceLens mengubahnya menjadi schema event kanonik sehingga data dapat dibandingkan.

3.2 Timeline manual

Mencari kejadian penting dari ribuan baris log memerlukan waktu. Timeline engine menyatukan event lintas file berdasarkan timestamp_normalized, lalu memakai provenance sebagai tie-breaker deterministik.

3.3 Korelasi entitas

Aktivitas penyerang dapat menggunakan IP, akun, atau session yang sama pada beberapa event. Correlation engine menghubungkan event dalam window waktu configurable dan selalu menyimpan alasan yang eksplisit.

3.4 Risiko halusinasi AI

Model bahasa dapat menghasilkan kalimat yang masuk akal tetapi tidak didukung log. TraceLens menerapkan structured claim, status fact/inference/hypothesis, evidence ownership check, dan rebuilding jawaban dari claim yang lolos validator.

4. Prinsip Arsitektur

Prinsip	Implementasi
Deterministic first	Parsing, timestamp, sorting, correlation, finding, dan scoring menggunakan Python/regex
Evidence grounded	Event menyimpan raw log, nomor baris, file bukti, dan evidence ID
Case isolation	Query dan tool AI dibatasi pada case yang sedang aktif
Explainable	Correlation reason dan risk score breakdown disimpan
Immutable evidence	File diberi hash dan field raw event dijaga dari perubahan
Honest uncertainty	Claim tanpa dukungan cukup ditolak atau dinyatakan belum cukup bukti
Auditable	Upload, chat, citation, integrity check, dan export dicatat

5. Gambaran Arsitektur Sistem



Tanggung jawab komponen:

Komponen	Teknologi	Tanggung jawab utama
Frontend	Next.js, React	Dashboard, upload, timeline, explorer, chat, findings, report
API	FastAPI	Authentication, authorization, validation, query, audit, AI orchestration
Database	PostgreSQL	Case, membership, evidence metadata, event, correlation, finding, audit
Queue	Redis	Celery broker dan fixed-window rate limiter
Worker	Celery	Deteksi format, parsing, normalisasi, dan rebuild deterministic analysis
Storage	Docker volume	Menyimpan file evidence menggunakan nama internal UUID
LLM provider	GitHub Models	Tool selection, interpretasi, hipotesis, dan structured claims

4.1 Konfigurasi AI yang sedang digunakan

Konfigurasi provider dibaca dari environment dan tidak ditanam di source code. Parameter penting untuk audiensi:

```
GITHUB_MODELS_ENDPOINT=https://models.github.ai/inference
GITHUB_MODELS_MODEL=<model tool-calling yang dipilih>
LLM_MAX_TOOL_ROUNDS=8
LLM_MAX_TOOL_CALLS=20
```

LLM_MAX_TOOL_CALLS=20 adalah pagar operasional: satu pertanyaan investigator tidak boleh memicu tool-call tanpa batas. Nilai ini mengontrol biaya, latency, dan risiko loop agent; nilai tersebut bukan jaminan bahwa model selalu benar. Token harus tetap disimpan hanya pada .env atau secret manager, bukan pada repository atau dokumen presentasi.

5.1 Trust boundary

Ada tiga boundary penting:

- **Untrusted upload boundary:** nama dan isi file dianggap tidak tepercaya.

- **Deterministic analysis boundary:** hasil parsing dan correlation dibuat oleh kode yang dapat diuji.
- **LLM boundary:** seluruh tool output diperlakukan sebagai data, bukan instruksi.

6. Alur End-to-End

6.1 Membuat case

Investigator login, membuat case, dan memperoleh akses berdasarkan membership serta role. Semua endpoint case harus memverifikasi bahwa user menjadi anggota case.

6.2 Upload evidence

Backend:

1. memeriksa extension, MIME type, ukuran, UTF-8, dan sampel isi;
2. membersihkan pengaruh nama file pengguna;
3. menyimpan file memakai UUID internal;
4. menghitung SHA-256 selama streaming;
5. membuat record `evidence_files`;
6. mencatat audit upload;
7. mengirim job parsing ke Celery.

6.3 Parsing

Worker mendeteksi format berdasarkan pola beberapa baris awal, bukan extension saja. Parser mengubah record menjadi canonical event. Setiap event mempertahankan:

- `raw_log`;
- `raw_line_number`;
- `evidence_file_id`;
- `parser_name`;
- `parser_confidence`;
- timestamp asli dan hasil normalisasi;
- asumsi tahun atau timezone.

6.4 Timeline dan correlation

Urutan logis timeline:

```
timestamp_normalized  
-> timestamp confidence/provenance  
-> raw_line_number  
-> evidence_file_id  
-> event_id
```

Correlation menggunakan shared source IP, username, atau session dalam window waktu. Contoh alasan:

```
shared source_ip within 10 minutes (0.5 minutes apart)
```

6.5 Detection dan risk scoring

Rule yang sudah tersedia berfokus pada:

- repeated failed authentication atau brute force;

- successful login setelah kegagalan berulang dari IP yang sama.

Formula risk score:

```
severity_weight * 0.30
+ frequency_score * 0.20
+ privilege_weight * 0.25
+ correlation_count * 0.15
+ novelty_score * 0.10
```

Skor harus selalu disertai nilai masing-masing komponen. Skor adalah alat prioritisasi, bukan vonis bahwa insiden pasti berbahaya.

6.6 AI investigation

Agent dapat memanggil enam tool read-only:

1. search_events
2. get_surrounding_events
3. build_timeline
4. correlate_entities
5. get_raw_evidence
6. generate_case_summary

Agent tidak diberi kemampuan mengubah raw event, correlation, atau finding. Tool memaksakan active case ID dan mengembalikan data dalam delimiter untrusted content.

6.7 Claim verification gate

Respons agent mengikuti bentuk konseptual:

```
{
  "answer": "Ringkasan yang sudah diverifikasi",
  "claims": [
    {
      "text": "Terjadi beberapa kegagalan login dari IP tertentu.",
      "status": "fact",
      "evidence_id": "UUID event"
    }
  ]
}
```

Validator memeriksa:

- status hanya fact, inference, atau hypothesis;
- evidence ID berbentuk valid;
- evidence berada dalam case aktif;
- jumlah minimum bukti sesuai jenis claim;
- metadata confidence, limitation, dan kebutuhan bukti tambahan;
- entity, outcome, atau count dasar sesuai event yang dirujuk.

Jawaban final dibangun ulang dari claim yang lolos. Valid evidence ID membuktikan bahwa citation ada dan dimiliki case, tetapi belum merupakan pembuktian formal bahwa seluruh makna kalimat pasti benar. Karena itu investigator tetap harus membuka raw evidence.

7. Fitur yang Dilihat Audiensi

7.1 Case Dashboard

Menampilkan total log, rentang waktu, risk summary, host, user, IP, status parsing, dan ringkasan investigation workload.

7.2 Log Upload

Menyediakan drag-and-drop, progress/status job, detected format, parser result, dan error yang dapat ditindaklanjuti.

7.3 Timeline

Menyatukan event dari beberapa file dalam urutan waktu yang konsisten. Filter severity dan source membantu mempersempit investigasi.

7.4 Event Explorer

Menyediakan pencarian, filter, detail canonical event, raw log, serta konteks event sebelum dan sesudah.

7.5 AI Investigator Chat

Memisahkan narasi, status claim, dan evidence block secara visual. Citation dapat diklik untuk membuka raw log.

7.6 Findings and Report

Menampilkan finding rule-based, risk breakdown, workflow status, rekomendasi, dan export Markdown/PDF.

8. Model Data Inti

Entitas	Fungsi
cases	Wadah investigasi
case_memberships	Role user pada case
evidence_files	Metadata file, SHA-256, status parsing, storage path
events	Canonical event dan raw provenance
correlations	Hubungan event beserta alasan
findings	Pola rule-based dan risk breakdown
agent_runs	Lifecycle dan state agent
audit_logs	Aktivitas penting serta metadata transformasi

Field paling penting untuk chain-of-custody adalah SHA-256 evidence file, raw log, raw line number, evidence file ID, parser version, timestamp assumptions, model version, dan prompt version.

9. Kontrol Keamanan yang Sudah Ada

9.1 Authentication dan session

- password di-hash menggunakan PBKDF2 dengan salt;
- session token dibuat acak dan hanya hash-nya disimpan server-side;
- cookie menggunakan HttpOnly;

- SameSite policy diterapkan;
- CSRF token digunakan untuk operasi state-changing.

9.2 Authorization dan case isolation

- role global dan membership per-case;
- query harus menyertakan case scope;
- evidence ID diperiksa kembali terhadap case aktif;
- policy test tersedia untuk cross-case access.

9.3 Upload security

- batas ukuran;
- allowlist extension dan MIME;
- validasi encoding serta pola isi;
- UUID storage filename;
- canonical path validation;
- SHA-256;
- read-only permission pada evidence.

9.4 Prompt injection defense

- raw log dianggap untrusted data;
- delimiter memisahkan instruksi sistem dan data;
- model diminta mengabaikan perintah yang muncul dalam log;
- raw log tidak dikirim ke provider eksternal secara default;
- redaction diterapkan pada pola secret tertentu;
- tool allowlist dan active case binding.

9.5 Container hardening

Production overlay menerapkan non-root user, read-only filesystem, dropped Linux capabilities, dan no-new-privileges. TLS termination, secret manager eksternal, dan network segmentation production masih perlu disediakan oleh environment deployment.

10. Hasil Validasi Aktual

Review dilakukan secara read-only terhadap repository dan runtime lokal.

Pemeriksaan	Hasil
Backend unit tests	53 lulus
Frontend TypeScript	Lulus
Next.js production build	Lulus
Docker Compose configuration	Valid
Backend health/readiness dasar	Aktif
PostgreSQL	Healthy

Pemeriksaan	Hasil
Redis	Healthy
Celery worker	Aktif, concurrency 4
Celery scheduler	Aktif
Alembic current database	Revision head
Detection evaluation	6/6
Offline grounding evaluation	5/5
npm production audit	Gagal, 3 high vulnerabilities

Interpretasi yang jujur:

- test yang lulus membuktikan banyak unit berfungsi sesuai ekspektasi;
- corpus evaluation masih kecil dan curated;
- belum ada bukti cukup untuk mengklaim akurasi universal;
- build sukses tidak sama dengan aman untuk production;
- database yang sudah berjalan tidak membuktikan fresh migration aman.

11. Scorecard Review

Area	Nilai	Penjelasan
Arsitektur aplikasi	4.0/5	Pemisahan komponen dan deterministic/LLM boundary jelas
Evidence integrity	4.2/5	Provenance, hash, raw log, line number, dan audit sudah kuat
AI grounding	4.0/5	Structured claim dan verification gate matang untuk MVP
Frontend/UX	3.7/5	Alur investigator lengkap dan evidence dibedakan visual
Security	2.9/5	Masih ada login rate limit, dependency, dan secret history issue
Reliability	2.8/5	Ada concurrency race, memory pressure, dan readiness gap
Testing	3.1/5	Unit test baik, integrasi production-equivalent belum cukup
Operations	3.0/5	Monitoring dasar ada, backup dan restore chain belum lengkap
Nilai keseluruhan	3.4/5	Strong MVP, belum production-ready

12. Temuan Prioritas Tinggi

12.1 Fresh database migration berpotensi gagal

Migration baseline menggunakan `Base.metadata.create_all`. Metadata tersebut mengikuti model terbaru. Pada database kosong, baseline dapat membuat kolom versi baru sebelum migration berikutnya mencoba menambahkan kolom yang sama.

Dampak:

- deployment baru dapat gagal;
- disaster recovery ke database kosong tidak dapat dipercaya;
- startup DDL dapat menyamarkan drift migration.

Perbaikan:

- buat migration baseline eksplisit dan immutable;
- jangan mengimpor live model pada revision lama;
- hilangkan `create_all` dan raw DDL dari startup setelah migration stabil;
- test `alembic upgrade head` pada PostgreSQL kosong;
- test upgrade dari revision lama.

12.2 Race condition rebuild analysis

Per-case lock pada worker dilepas sebelum database commit. Worker lain dapat memperoleh lock dan membaca state yang belum committed. Endpoint manual rebuild juga perlu menggunakan mekanisme lock yang sama.

Dampak:

- finding atau correlation duplikat;
- hasil analisis stale;
- unique constraint error;
- status job membingungkan.

Perbaikan:

- pertahankan lock sampai commit/rollback selesai;
- gunakan PostgreSQL advisory transaction lock;
- tambahkan analysis generation ID dan idempotency;
- lakukan parallel-ingestion integration test.

12.3 Frontend production dependencies rentan

Audit menemukan tiga high-severity vulnerabilities pada dependency tree Next.js, PostCSS, dan Sharp/libvips.

Perbaikan:

- upgrade minimal ke Next.js patch aman yang direkomendasikan audit;
- regenerasi lockfile;
- jalankan `npm audit`, `typecheck`, `build`, dan `E2E`;
- blok release ketika high/critical vulnerability masih ada.

12.4 Secret pernah masuk Git history

Working tree saat ini bersih, tetapi signature GitHub personal access token ditemukan pada commit lama. Menghapus token dari file terakhir tidak menghapusnya dari history.

Perbaikan:

- revoke token lama;
- buat token baru dengan least privilege;
- bersihkan history jika repository pernah dibagikan;
- aktifkan secret scanning dan push protection;
- audit fork, cache, release artifact, dan CI log.

12.5 Login belum di-rate-limit

Rate limiting tersedia pada upload dan chat, tetapi belum diterapkan pada login.

Perbaikan:

- limit per-IP dan per-username;
- exponential backoff atau temporary lockout;
- audit login gagal tanpa menyimpan password;
- gunakan error generik untuk mencegah account enumeration.

12.6 Unknown input diterima sebagai generic text

Input yang tidak cocok parser dapat diterima sebagai `generic_text`. Ini bertentangan dengan perilaku strict upload dan memperbesar kemungkinan false interpretation.

Perbaikan:

- reject unknown format secara default;
- letakkan parser experimental di belakang feature flag;
- tampilkan label supported/experimental/unknown;
- jangan menyebut JSON hasil konversi sebagai dukungan native EVTX.

13. Temuan Prioritas Menengah

13.1 Agent run gagal dapat tetap berstatus running

Run diselesaikan pada jalur sukses, tetapi error provider, timeout, atau budget dapat meninggalkan status running.

Solusi: tambahkan lifecycle running, completed, failed, timeout, dan cancelled, termasuk `finished_at` serta sanitized error.

13.2 Test suite masih unit-heavy

Sebagian test menggunakan SQLite, fake database, dan fake LLM client. Belum cukup menguji cookie/CSRF melalui HTTP, PostgreSQL trigger, Celery broker, fresh migration, upload paralel, dan browser citation flow.

Solusi:

- PostgreSQL/Redis integration environment;
- Celery end-to-end test;
- Playwright browser test;

- failure injection;
- large-file soak test;
- migration and restore test.

13.3 Readiness hanya memeriksa database

Sistem bisa melaporkan ready walaupun Redis, worker, queue, atau evidence volume bermasalah.

Solusi: pisahkan liveness dan readiness serta cek database, Redis, evidence storage, migration head, dan worker heartbeat.

13.4 Backup belum mencakup evidence

Backup saat ini berpusat pada pg_dump. Record database dapat dipulihkan tanpa file evidence yang dirujuk.

Solusi: backup database dan evidence sebagai satu manifest, verifikasi SHA-256, enkripsi, lakukan restore drill, dan dokumentasikan RPO/RTO.

13.5 Worker membaca seluruh file ke memori

Membaca seluruh file dan membuat banyak ORM object dapat meningkatkan konsumsi RAM ketika beberapa worker berjalan.

Solusi: streaming parser, batch insert, staging table, Celery task time limit, memory limit per child, dan kapasitas test.

14. Threat Model Ringkas

Ancaman	Mitigasi sekarang	Sisa risiko
Path traversal upload	UUID filename dan canonical path	Parser/library bug masih mungkin
File terlalu besar	Upload size limit	Memory expansion saat parsing
Cross-case data leak	Membership dan scoped query	Perlu integration/fuzz testing
Prompt injection dalam log	Delimiter, untrusted data, tool allowlist	Model tetap probabilistik
AI hallucination	Structured claims dan evidence gate	Citation belum membuktikan semantic entailment formal
Raw evidence modification	Hash dan immutable event fields	Host/database admin tetap privileged
Credential brute force	Session security	Login rate limit belum ada
Dependency exploitation	CI audit tersedia	Current frontend audit masih gagal
Data loss	Database backup script	Evidence backup/restore belum lengkap
Worker outage	Job status dan scheduler	Readiness belum mendeteksi seluruh dependency

15. Roadmap Perbaikan

P0 - Sebelum deployment publik

1. Revoke secret lama dan bersihkan Git history.
2. Perbaiki Alembic baseline serta fresh migration test.
3. Upgrade vulnerable frontend dependencies.

4. Perbaiki analysis lock dan concurrency test.
5. Terapkan login rate limiting.
6. Reject unknown log secara default.

P1 - Production candidate

1. Integration test PostgreSQL, Redis, Celery, dan browser.
2. Agent run failure lifecycle.
3. Dependency-aware readiness.
4. Evidence-inclusive backup dan restore drill.
5. Streaming/batched ingestion.
6. TLS, external secret manager, dan trusted proxy profile.

P2 - Forensic assurance

1. Object storage immutable atau WORM.
2. Cryptographically signed audit chain.
3. Stronger semantic claim validation.
4. Formal parser corpus dan external accuracy evaluation.
5. MFA/SSO dan lifecycle user lengkap.
6. Retention, legal hold, deletion, dan evidence handling policy.

16. Skenario Demo yang Direkomendasikan

Gunakan data sintetis atau data lab yang memang berwenang digunakan.

Langkah demo

1. Login dan buat case baru.
2. Unggah Linux auth log yang berisi login gagal berulang dan satu login berhasil.
3. Tunjukkan SHA-256, detected format, parser status, serta jumlah event.
4. Buka timeline dan tunjukkan urutan lintas file.
5. Klik event dan perlihatkan raw log serta nomor baris.
6. Buka finding brute force dan jelaskan risk breakdown.
7. Tanyakan: "Apa yang terjadi pada case ini?"
8. Tunjukkan badge fact/inference/hypothesis.
9. Klik evidence citation dan cocokkan dengan raw log.
10. Tanyakan sesuatu yang tidak ada buktinya.
11. Tunjukkan respons "belum cukup bukti".
12. Export laporan PDF.

Hal yang jangan diklaim saat demo

- "AI menjamin insiden ini benar."
- "Skor tinggi membuktikan serangan."

- "Semua format log otomatis didukung."
- "Sistem sudah siap production."
- "Citation membuktikan seluruh interpretasi pasti benar."

Gunakan kalimat:

- "Sistem mendeteksi pola yang perlu diprioritaskan investigator."
- "Claim ini didukung event berikut."
- "Interpretasi tetap harus dikonfirmasi manusia."
- "Format ini didukung secara deterministik."

17. FAQ Audiensi

Mengapa tidak menyerahkan semua log langsung kepada AI?

Karena output model probabilistik, mahal, sulit direproduksi, dan raw log dapat berisi prompt injection. Deterministic parser lebih mudah diuji dan diaudit.

Apakah evidence ID menghilangkan halusinasi sepenuhnya?

Tidak. Evidence ID mencegah claim tanpa citation dan mencegah citation lintas case. Validator semantic masih terbatas, sehingga investigator tetap wajib membuka bukti.

Mengapa raw log harus disimpan?

Canonical event adalah hasil transformasi. Raw log dan nomor baris diperlukan untuk memeriksa apakah transformasi benar dan menjaga traceability.

Apakah risk score adalah machine learning?

Tidak. Risk score memakai formula berbobot yang dapat dijelaskan dan ditampilkan komponennya.

Apakah sistem menggantikan SOC analyst?

Tidak. Sistem mengurangi pekerjaan mekanis dan membantu navigasi bukti. Keputusan insiden, containment, dan respons tetap berada pada investigator.

Apakah Windows EVTX didukung?

Belum secara native dalam batas MVP. JSON atau CSV hasil konversi tidak boleh disamakan dengan parser EVTX native.

Apa yang terjadi jika GitHub Models gagal?

Parsing, timeline, correlation, dan finding deterministik seharusnya tetap tersedia. Chat AI gagal dengan error terkontrol, tetapi lifecycle run masih perlu diperbaiki.

Apa pembeda utama TraceLens?

Pemisahan deterministic analysis dan generative interpretation, ditambah claim verification gate serta citation ke raw evidence.

18. Panduan Presentasi 12 Menit

Waktu	Materi	Pesan
0-1 menit	Masalah	Log heterogen dan AI dapat berhalusinasi
1-3 menit	Solusi	Deterministic pipeline plus evidence-grounded AI
3-5 menit	Arsitektur	Frontend, API, worker, database, evidence, LLM boundary
5-8 menit	Demo	Upload, timeline, finding, chat, citation
8-10 menit	Security	Case isolation, immutable evidence, injection defense
10-11 menit	Review jujur	Strong MVP dengan enam P0 blocker
11-12 menit	Roadmap	Production candidate lalu forensic assurance

19. Penutup

TraceLens AI sudah menunjukkan desain yang matang untuk sebuah MVP evidence-grounded. Nilai terkuatnya bukan sekadar kemampuan memakai AI, melainkan pembatasan yang jelas terhadap AI: pekerjaan yang harus deterministik tetap dilakukan oleh kode, sedangkan interpretasi AI harus melewati verification gate.

Posisi yang tepat saat ini adalah **strong MVP**. Sistem sudah pantas dipresentasikan, diuji dalam lab, dan dikembangkan sebagai portfolio atau penelitian. Sistem belum pantas dipasarkan sebagai platform production forensics sampai seluruh P0 selesai dan pengujian integration-production diperluas.

Kalimat penutup untuk audiensi:

Tujuan TraceLens bukan membuat AI terdengar paling yakin. Tujuannya adalah membuat setiap pernyataan AI dapat diperiksa, ditolak, atau dibuktikan kembali dari evidence asli.

Lampiran A - Checklist sebelum presentasi

- Pastikan Docker services healthy.
- Gunakan case baru dan sample log yang sudah diuji.
- Pastikan provider AI aktif; siapkan fallback screenshot jika API limit.
- Jangan tampilkan .env, token, password, atau data pribadi.
- Pastikan citation dapat dibuka.
- Siapkan satu pertanyaan dengan bukti cukup dan satu pertanyaan tanpa bukti.
- Pastikan PDF export berhasil.
- Jelaskan limitation secara proaktif.

Lampiran B - Referensi internal proyek

- README.md
- docs/ARCHITECTURE.md
- docs/THREAT_MODEL.md

- docs/PRODUCTION_READINESS.md
- docs/BUILD_VALIDATION_REPORT.md
- docs/IMPROVEMENT_IMPLEMENTATION_STATUS.md
- backend/app/claim_verifier.py
- backend/app/llm_gateway.py
- backend/app/engine.py
- backend/app/tasks.py

Dokumen ini adalah hasil review teknis repository lokal pada 28 Juli 2026. Status dapat berubah setelah dependency, migration, test, atau konfigurasi diperbarui.